

EncryptEdge Labs

Junior Cloud Security Engineer Internship Programme

Junior Cloud Security Engineer Internship Task Report

Task ID	CSE-AWS-L-005-04
Task Title	AWS Identity and Access Management Architecture and Security Design
Skill Domain	AWS IAM / Cloud Access Control
Difficulty	Intermediate
Duration	14 Hours
CPE Credits	4 CPE Credits
Cloud Platform(s)	AWS Free Tier account with IAM users, roles, groups, and trust relationships
AWS Region(s) Used	us-east-2
Primary Tools	AWS CLI, AWS Management Console, IAM Policy Simulator, CloudShell, ChatGPT or Claude for AI-assisted analysis
Target Environment	AWS Free Tier account with IAM users, roles, groups, and trust relationshipsPwnedLabs lab / Cybr lab
MITRE ATT&CK IDs	T1078 (Valid Accounts), T1098 (Account Manipulation), T1550 (Use of Web Session Cookie)
Guiding Frameworks	CIS AWS Foundations Benchmark v1.5, NIST SP 800-53, ISO 27001, OWASP Cloud Top 10
Regulatory Alignment	[e.g. ISO 27001 A.9 Access Control, A.12 Operations Security; NICE PR-CDA-001; SFIA Level 3-4]

1.1 Introduction

This project focused on understanding and securing AWS Identity and Access Management (IAM) by applying the principle of least privilege in an isolated AWS Free Tier environment. The lab involved creating IAM users, groups, roles, and policies, identifying overly permissive access, and redesigning policies to reduce security risks. These skills are essential for cloud security engineers because IAM misconfigurations are a common cause of unauthorized access, privilege escalation, and cloud security breaches.

1.2 Objectives & Learning Outcomes

Objective 1: Understand the core components of AWS IAM—users, groups, roles, and policies—and how they enforce access control across services.

How I met it: I reviewed AWS IAM concepts and used the IAM Policy Simulator to test permissions and observe how policies result in allowed or denied actions.

Objective 2: Configure an isolated environment in an AWS Free Tier account to safely explore IAM configurations.

How I met it: I created `intern_user`, `intern_group`, and `intern_role`, attached `AmazonS3ReadOnlyAccess` and a custom `EC2DescribeInstances` policy, assigned the user to the group, and verified the configuration using AWS CloudShell.

Objective 3: Enumerate existing IAM entities and analyze their relationships for potential misconfigurations.

How I met it: I used AWS CLI commands to enumerate IAM users, groups, roles, and policies, analyzed permissions for excessive access, and documented the findings in `policy_analysis.json`.

Objective 4: Redesign insecure policies using least-privilege principles and validate them through simulation.

How I met it: I created a bucket-specific policy for the `my-homelab-trail` S3 bucket, validated permissions using the IAM Policy Simulator and AWS CLI, and developed a threat model identifying assets, threats, and mitigations.

Objective 5: Use external labs to reinforce IAM and cloud security learning.

How I met it: I completed additional cloud security labs to strengthen my practical understanding of IAM, least-privilege access control, and cloud security best practices, and documented the results with supporting evidence.

1.2 Scope & Legal Authorisation

All activities performed during this task were conducted within authorised learning environments specifically created for cloud security training. No testing was performed against production systems, third-party cloud environments, or customer-owned resources.

Authorised environments used:

- **Personal AWS Free Tier account** used to configure and manage IAM users, groups, roles, policies, and S3 resources within an isolated lab environment.
- **AWS IAM Security Homelab** hosted in the personal AWS Free Tier account to perform IAM configuration, policy analysis, least-privilege implementation, and policy simulation.
- **AWS IAM Policy Simulator** used to validate IAM permissions and verify allowed and denied actions before and after applying least-privilege policies.
- **AWS CloudShell** used to execute AWS CLI commands for IAM enumeration, policy validation, and configuration verification.

- **AI-assisted analysis (ChatGPT)** used only to review IAM policy JSON, explain security concepts, generate documentation, and recommend least-privilege improvements. AI tools were **not** used to execute AWS commands, create cloud resources, or generate technical evidence.

Authorisation Statement

All testing was conducted exclusively within my personal AWS Free Tier account for educational purposes. No external AWS accounts, production environments, third-party cloud resources, or real customer data were accessed. All resources were created and managed solely within the authorised homelab environment, and all evidence collected was generated from this environment in accordance with the lab requirements.

1.4 MITRE ATT&CK Cloud Threat Mapping

MITRE ATT&CK Technique ID	Technique Name	Relevance to This Task
T1078	Valid Accounts	The lab focused on securing valid IAM users (intern_user) and controlling access through IAM groups, roles, and policies to prevent unauthorized use of legitimate credentials.
T1098	Account Manipulation	IAM users, groups, roles, and policies were created and modified to demonstrate how excessive permissions can increase security risk and how least-privilege policies reduce that risk.
T1530	Data from Cloud Storage Object	The lab redesigned S3 permissions to restrict access only to the my-homelab-trail bucket, reducing the risk of unauthorized access to cloud storage objects.
T1087	Account Discovery	AWS CLI commands such as list-users, list-groups, list-policies, and get-role were used to enumerate IAM identities and analyze their relationships for potential misconfigurations.
T1562.001	Impair Defenses: Disable or Modify Tools	The threat model considered the risk of overly permissive IAM policies that could weaken security controls. Applying least-privilege permissions and CloudTrail monitoring helps prevent unauthorized modification of security configurations.

2.0 Environment & Tool Setup

2.1 Cloud Architecture Overview

Cloud Resource / Component	Type / Service	Role in Task	Region / Config Notes
AWS Free Tier Account	AWS Account	Isolated cloud environment used for all IAM security exercises	Personal AWS Free Tier account
intern_user	AWS IAM User	Test user used to verify permissions and access control	Member of intern_group
intern_group	AWS IAM Group	Groups IAM permissions and simplifies access management	Attached AmazonS3ReadOnlyAccess and custom inline policy
intern_role	AWS IAM Role	Demonstrates role-based access and trust relationships	Trusted entity: ec2.amazonaws.com
AmazonS3ReadOnlyAccess	AWS Managed IAM Policy	Provides read-only access to Amazon S3	Replaced in Phase D with a least-privilege bucket-specific policy
EC2DescribeInstances	IAM Inline Policy	Allows viewing EC2 instance information	Action: ec2:DescribeInstances; Resource: *
my-homelab-trail	Amazon S3 Bucket	Storage resource used to demonstrate least-privilege access	Bucket-specific policy created in Phase D
IAM Policy Simulator	AWS IAM Tool	Validated IAM policies by testing allowed and denied actions	Used in Phase A and Phase D
AWS CloudShell	AWS CloudShell	Executed AWS CLI commands for IAM enumeration and verification	Used for get-user, list-groups, get-role, and policy simulation
AWS CLI	AWS Command Line Interface	Enumerated IAM resources and verified permissions	Configured with AWS credentials for Account

2.2 AWS CLI & Tool Configuration

Tool / Service	Version	Installation Method	Purpose in This Task
AWS CLI	v2.x	Installed from the AWS CLI installer and configured using aws configure with an IAM access key and secret key.	Executed IAM commands to enumerate users, groups, roles, and policies, and verified IAM configurations.
AWS CloudShell	AWS Managed	Available through the AWS Management Console (no installation required).	Executed AWS CLI commands for IAM verification, policy analysis, and permission validation.
AWS IAM Policy Simulator	Web Console	Available in the AWS IAM Console (no installation required).	Tested IAM policies and verified allowed and denied actions before and after applying least-privilege permissions.
AWS IAM Console	AWS Managed	Available through the AWS Management Console (no installation required).	Created and managed IAM users, groups, roles, managed policies, and inline policies.
Amazon S3	AWS Managed	Created through the AWS Management Console.	Hosted the my-homelab-trail bucket used to implement and validate bucket-specific least-privilege access.
ChatGPT (AI Assistant)	GPT-5.5	Web-based service (no installation required).	Reviewed IAM policy JSON, explained IAM concepts, assisted with threat modelling, and helped prepare technical documentation.

Key Configuration Commands Used

The following commands were used to configure the AWS CLI and verify connectivity before performing the lab activities.

Configure AWS CLI

```
aws configure
```

```
AWS Access Key ID [*****XXXX]: *****
```

```
AWS Secret Access Key [*****XXXX]: *****
```

```
Default region name [None]: us-east-1
```

```
Default output format [None]: json
```

Verify AWS Identity

```
aws sts get-caller-identity
```

Output

```
{
```

```
"UserId": "AIDA5VAX2ZKE04TQB0AA0",  
"Account": "*****",  
"Arn": "arn:aws:iam::*****:user/test-user"  
}
```

Verify IAM User Configuration

```
aws iam get-user --user-name intern_user
```

Output

```
{  
  "User": {  
    "UserName": "intern_user",  
    "UserId": "AIDA5VAX2ZKEFE6HUIR5J",  
    "Arn": "arn:aws:iam::*****:user/intern_user",  
    "CreateDate": "2026-08-05T20:19:51+00:00"  
  }  
}
```

2.3 AI Tool Usage Declaration

AI Tools Used: ChatGPT (OpenAI GPT-5.5)

ChatGPT was used to:

- Explain AWS IAM concepts, least-privilege principles, and IAM policy behaviour.
- Review IAM policy JSON files and identify excessive permissions.
- Recommend least-privilege IAM policy improvements for the my-homelab-trail S3 bucket.
- Assist in developing the threat model, MITRE ATT&CK mapping, and risk analysis.
- Help prepare technical documentation, report content, and evidence descriptions.

AI assistance was used **only for explanation, analysis, and documentation**. All AWS resources, IAM users, groups, roles, policies, AWS CLI commands, and technical evidence were created, executed, and validated within my authorised AWS Free Tier environment.

3.0 Methodology — Phase Execution

Phase A: Understand the core components of AWS IAM—users, groups, roles, policies—and how they enforce access control across services.

Phase Objective	Understand the core components of AWS IAM—users, groups, roles, policies—and how they enforce access control across services.
Estimated Time	~90 minutes
Evidence File(s)	PhaseA-Policy-Simulation.png

Actions Taken

In this phase, I reviewed the AWS Identity and Access Management (IAM) documentation to understand the core concepts of users, groups, roles, policies, authentication, authorization, and trust relationships. I also studied the principle of least privilege and how IAM policies are evaluated to allow or deny access to AWS resources.

Using the AWS IAM Policy Simulator, I tested a sample policy granting s3:* permissions and observed which actions were allowed or denied. This demonstrated how IAM policies enforce access control and highlighted the risks of assigning overly broad permissions.

I also reviewed the **MITRE ATT&CK** techniques relevant to IAM security, including **T1078 (Valid Accounts)**, **T1098 (Account Manipulation)**, and **T1530 (Data from Cloud Storage Object)** to understand how attackers may abuse valid credentials or excessive cloud permissions.

AI Prompt Used

"Explain the difference between IAM users, groups, roles, authentication, authorization, and least privilege in AWS, and why overly permissive IAM policies increase security risk."

The response was used to improve my understanding of IAM concepts and was rewritten in my own words for this report.

Key Observations

This phase demonstrated that IAM is the foundation of access control in AWS. Users authenticate to AWS, while permissions are granted through policies attached to users, groups, or roles. I learned that following the principle of least privilege significantly reduces the attack surface by limiting access to only the resources and actions required for a specific task.

The Policy Simulator showed how a single policy change can affect access decisions without modifying live resources, making it a valuable tool for validating permissions before deployment. I also observed that overly broad permissions, such as unrestricted S3 access, increase the risk of unauthorized data access and privilege escalation if an IAM identity is compromised.

Evidence Produced

PhaseA-Policy-Simulation.png- — Screenshot of AWS IAM Policy Simulator showing allowed and denied actions.

Phase B: Configure an isolated environment in your own AWS Free Tier account to safely explore IAM configurations.

Phase Objective	Configure an isolated environment in your own AWS Free Tier account to safely explore IAM configurations.
Estimated Time	~120 minutes
Evidence File(s)	[e.g. PhaseB_VPC_Setup.png, PhaseB_CloudTrail_Config.png, PhaseB_IAMPolicy.json, PhaseB_identity.png]

Actions Taken

In this phase, I configured an isolated AWS IAM environment within my personal AWS Free Tier account to safely explore identity and access management. Using the AWS Management Console, I created an IAM user (intern_user), an IAM group (intern_group), and an IAM role (intern_role) to demonstrate role-based and group-based access control.

I attached the AWS managed policy **AmazonS3ReadOnlyAccess** to the intern_group and created a custom inline policy named **EC2DescribeInstances** that allows only the ec2:DescribeInstances action. The intern_user was then added to the intern_group to inherit the assigned permissions.

After configuring the IAM resources, I used AWS CloudShell and the AWS CLI to verify that the user, group, role, and attached policies were created successfully. The command outputs confirmed that the IAM configuration matched the intended design.

AWS CLI Commands Used

```
aws iam get-user --user-name intern_user
```

```
aws iam list-attached-group-policies --group-name intern_group
```

```
aws iam list-group-policies --group-name intern_group
```

```
aws iam get-role --role-name intern_role
```

Key Observations

This phase demonstrated how AWS IAM separates identities from permissions by assigning access through groups and roles rather than directly to users. Using a managed policy together with a custom inline policy showed how permissions can be tailored to specific operational requirements while following the principle of least privilege.

The AWS CLI verification commands confirmed that the resources were successfully created and correctly associated. I also observed that using IAM groups simplifies permission management because users inherit permissions from the group instead of requiring individual policy assignments.

Evidence Produced

- **phaseB_user.png** – Screenshot showing the successful creation of the intern_user IAM user.
- **phaseB_group.png** – Screenshot showing the intern_group with the attached AmazonS3ReadOnlyAccess managed policy.
- **phaseB_inline_policy.png** – Screenshot of the custom inline policy EC2DescribeInstances.
- **phaseB_user_group_membership.png** – Screenshot confirming intern_user is a member of intern_group.
- **phaseB_role.png** – Screenshot showing the successful creation of the intern_role.
- **phaseB_output.txt** – AWS CLI output confirming the IAM user, group, role, and attached policies were successfully configured.

Phase C: Enumerate existing IAM entities and analyze their relationships for potential misconfigurations.

Phase Objective	Enumerate existing IAM entities and analyze their relationships for potential misconfigurations.
Estimated Time	~180 minutes
Evidence File(s)	[e.g. PhaseC_results.log, PhaseC_query_output.png, PhaseC_policy_test.json, PhaseC_assume_chain.json]

Actions Taken

In this phase, I enumerated the AWS IAM environment to identify existing users, groups, roles, and policies and to assess their relationships for potential security misconfigurations. Using AWS CloudShell and the AWS CLI, I gathered information about IAM resources and verified the permissions assigned to the configured identities.

The IAM policies were reviewed to identify excessive permissions and opportunities to improve access control. I documented the findings in policy_analysis.json, including risk levels and recommended mitigations based on the principle of least privilege. I also used AI assistance to review the policy JSON and compare the existing permissions with more secure alternatives.

AWS CLI Commands Used

aws iam list-users

aws iam list-groups

aws iam list-policies --scope Local

aws iam get-role --role-name intern_role

```
aws iam list-attached-group-policies --group-name intern_group
```

```
aws iam list-group-policies --group-name intern_group
```

Key Observations

This phase demonstrated the importance of regularly reviewing IAM configurations to identify excessive permissions before they can be exploited. Enumerating IAM users, groups, roles, and policies provided a clear understanding of how permissions are inherited and how misconfigured policies can increase the attack surface.

The policy review showed that the AWS managed policy AmazonS3ReadOnlyAccess provides broader access than required for the lab environment. Applying the principle of least privilege by restricting access to only the required S3 bucket significantly reduces the risk of unauthorized data access. The AWS CLI also proved to be an effective tool for validating IAM configurations and identifying potential security issues.

Evidence Produced

- phaseC_policy_analysis.json – Analysis of IAM users, groups, roles, and policies, including identified risks and recommended mitigations.
- phaseC_ai_feedback.png – Screenshot of the AI-assisted policy review highlighting excessive permissions and least-privilege recommendations.

Phase D: Redesign insecure policies using least privilege principles and validate them through simulation.

Phase Objective	Redesign insecure policies using least privilege principles and validate them through simulation.
Estimated Time	~90 minutes
Evidence File(s)	[e.g. PhaseD_HardenedPolicy.json, PhaseD_RiskMatrix.xlsx, PhaseD_ThreatModel.png, PhaseD_AIAnalysis.txt]

Actions Taken

In this phase, I improved the IAM configuration by redesigning an overly permissive S3 policy using the principle of least privilege. Instead of allowing broad S3 read access, I created a custom IAM policy that restricts access to only the **my-homelab-trail** S3 bucket. This reduced the potential attack surface while still providing the permissions required for the lab.

To validate the updated permissions, I used the AWS IAM Policy Simulator and the AWS CLI to simulate policy evaluation for the intern_user IAM account. The simulation confirmed that the user was granted access only to the permitted S3 resources. Finally, I developed a threat model identifying the key assets, potential threats, and security controls implemented to reduce the risk of privilege escalation and unauthorized access.

AWS CLI Command Used

```
aws iam simulate-principal-policy \  
--policy-source-arn arn:aws:iam::938500344456:user/intern_user \  
--action-names s3:GetObject \  
--resource-arns arn:aws:s3:::my-homelab-trail/test.txt
```

Key Observations

This phase reinforced the importance of applying the principle of least privilege when designing IAM policies. Restricting S3 permissions to a single bucket significantly reduced the risk of unauthorized access compared with using a broad managed policy.

The policy simulation confirmed that the updated permissions functioned as expected before deployment, reducing the likelihood of configuration errors. Developing the threat model also highlighted how controls such as MFA, CloudTrail logging, scoped IAM policies, and regular permission reviews work together to reduce the risk of privilege escalation and protect cloud resources.

Evidence Produced

phased_threat_model.pdf – Threat model identifying assets, threats, mitigations, and residual risks.

phaseD_simulation.txt – AWS CLI policy simulation output validating the updated IAM permissions.

Phase E: Use external labs to reinforce learning.

Phase Objective	Use external labs to reinforce learnin.
Estimated Time	~240minutes
Evidence File(s)	PhaseE_CyberMind_Lab.png

Actions Taken

In this phase, I completed additional cloud security training labs to reinforce the AWS IAM concepts learned throughout the previous phases. These external exercises provided practical experience with identity and access management, least-privilege access control, policy evaluation, and cloud security best practices in a controlled training environment.

During the labs, I reviewed IAM configurations, analyzed permission assignments, and applied secure access control principles to identify and remediate common security issues. The exercises strengthened my understanding of how IAM policies, roles, and permissions protect AWS resources and reduce the risk of unauthorized access.

The completion of each lab was documented with screenshots and completion evidence to demonstrate successful execution of the required learning activities.

Key Observations:

The external labs reinforced the importance of implementing least-privilege access control and regularly reviewing IAM configurations to identify excessive permissions. Repeating these tasks in different environments improved my confidence in configuring IAM resources, interpreting policy behaviour, and applying cloud security best practices.

I also observed that combining hands-on practice with documentation and policy analysis provides a better understanding of how security controls protect cloud resources and reduce the likelihood of misconfigurations that could lead to privilege escalation or unauthorized access.

Evidence Produced

- PhaseE_CyberMind_Lab.png– Screenshot showing successful completion of the external cloud security lab.

Phase F: Use external labs to reinforce learning.

Phase Objective	Compile all findings into a professional report summarizing architecture design decisions and risk mitigations.
Estimated Time	180minutes
Evidence File(s)	

Actions Taken

In this phase, I compiled the evidence and findings from all previous phases into a structured technical report. The report documented the AWS IAM homelab configuration, IAM policy analysis, least-privilege implementation, threat modelling, and risk mitigation activities performed throughout the project.

The report includes screenshots, AWS CLI outputs, policy analysis, threat model diagrams, and supporting documentation to demonstrate the successful completion of each phase. The findings were organised into logical sections covering the cloud architecture, tools used, implementation steps, security observations, and recommendations. The report was reviewed to ensure that all evidence was clearly labelled, technically accurate, and aligned with the task requirements.

Key Observations:

Preparing the final report demonstrated the importance of documenting cloud security activities in a clear and structured manner. Consolidating technical evidence, configuration details, and security findings improved traceability and provided a comprehensive record of the implementation process.

The completed report highlighted how applying least-privilege principles, validating IAM permissions, and documenting identified risks contribute to a stronger cloud security posture. It also reinforced the value of maintaining accurate technical documentation to support future audits, troubleshooting, and compliance activities.

Evidence Produced

- labE_results.png – Screenshot showing successful completion of the external cloud security lab.

Risk Matrix (Phase D Output)

Cloud Asset / Resource	Threat / Risk	MITRE Ref.	Likelihood (1–5)	Impact (1–5)	Score	Rating
Amazon S3 Bucket (my-homelab-trail)	Broad S3 read permissions could allow unauthorized access to objects if IAM credentials are compromised.	T1530	3	4	12	High
IAM Role (intern_role)	Privilege escalation through an overly permissive trust policy or incorrect role assignment.	T1078	2	5	10	High
IAM User / Group (intern_user, intern_group)	Excessive IAM permissions through managed policies may grant unnecessary access beyond business requirements.	T1098	3	3	9	Medium

4.0 Findings

#	Finding Title	Type / Category	Cloud Service / Resource	MITRE Ref.	Phase	Severity	Evidence Ref.
1	Broad S3 Read Permissions	Access Control Weakness / IAM Policy Gap	Amazon S3 (my-homelab-trail)	T1530	Phase C & D	High	policy_analysis.json, phaseD_policy.json, threat_model.pdf
2	Excessive IAM Permissions Through Managed Policy	Misconfiguration / Access Control Weakness	IAM Group (intern_group)	T1098	Phase C	Medium	policy_analysis.json, phaseC_ai_feedback.png
3	Potential Privilege Escalation Through IAM Role Trust Policy	Privilege Escalation Path	IAM Role (intern_role)	T1078	Phase C & D	High	policy_analysis.json, threat_model.pdf
4	Least-Privilege IAM Policy Successfully Implemented	Security Improvement / Risk Mitigation	IAM Policy / Amazon S3	N/A	Phase D	Info	phaseD_policy.json, phaseD_simulation.txt, threat_model.pdf

4.2 Detailed Finding Analysis

Finding 1: Broad S3 Read Permissions

Field	Details
Finding Title	Broad S3 Read Permissions
Type / Category	Access Control Weakness / IAM Policy Gap
Cloud Service / Resource	Amazon S3 Bucket (my-homelab-trail)
Description	The intern_group was initially assigned the AWS managed policy AmazonS3ReadOnlyAccess , which provides broader read permissions than required for the lab. This exceeded the principle of least privilege because access was not restricted to the specific S3 bucket used during testing.
How Identified	AWS IAM Policy Review, AWS CLI enumeration (aws iam list-attached-group-policies), and AI-assisted policy analysis.
MITRE ATT&CK Reference	T1530 – Data from Cloud Storage Object
Business / Security Impact	Excessive S3 permissions could allow unauthorized access to cloud storage objects if valid IAM credentials are compromised, increasing the risk of data exposure.

Field	Details
Severity / Impact	High
Evidence Reference	phaseC_policy_analysis.json, phaseC_ai_feedback.png

Finding 2: Excessive IAM Permissions Through Managed Policy

Field	Details
Finding Title	Excessive IAM Permissions Through Managed Policy
Type / Category	Misconfiguration / Access Control Weakness
Cloud Service / Resource	IAM Group (intern_group)
Description	The IAM group inherited permissions from the AWS managed policy AmazonS3ReadOnlyAccess , which granted broader access than necessary for the lab environment. The policy was suitable for general read-only access but not for a least-privilege configuration.
How Identified	AWS CLI (aws iam list-attached-group-policies) and AWS IAM Console permission review.
MITRE ATT&CK Reference	T1098 – Account Manipulation
Business / Security Impact	Excessive permissions increase the attack surface and may allow users to access resources beyond operational requirements if their credentials are compromised.
Severity / Impact	Medium
Evidence Reference	phaseC_policy_analysis.json, phaseC_ai_feedback.png

Finding 3: Potential Privilege Escalation Through IAM Role

Field	Details
Finding Title	Potential Privilege Escalation Through IAM Role
Type / Category	Privilege Escalation Path
Cloud Service / Resource	IAM Role (intern_role)

Field	Details
Description	The IAM role trust policy allows the EC2 service to assume the role. Although correctly configured for the lab, overly permissive trust relationships in production environments could enable unintended role assumption and privilege escalation.
How Identified	AWS CLI (aws iam get-role --role-name intern_role) and trust policy review.
MITRE ATT&CK Reference	T1078 – Valid Accounts
Business / Security Impact	Incorrect trust relationships can allow attackers to abuse valid identities or compromised services to obtain elevated permissions.
Severity / Impact	High
Evidence Reference	PhaseD_threat_model.pdf, phaseC_policy_analysis.json

5.0 Risk Assessment & Cloud Threat Model

5.1 Cloud Security Control Gaps & Defensive Coverage

Finding / Gap	Observable / Trigger in Cloud Telemetry	Recommended Control	AWS Service / Tool for Implementation
Broad S3 Read Permissions	Unusual GetObject or ListBucket API calls recorded in CloudTrail from unexpected IAM identities or locations.	Replace the managed policy with a bucket-specific least-privilege IAM policy, enable S3 Block Public Access , and periodically review bucket permissions.	AWS IAM, Amazon S3, AWS CloudTrail, IAM Access Analyzer
Excessive IAM Permissions Through Managed Policy	AttachUserPolicy, AttachGroupPolicy, or PutGroupPolicy events detected in CloudTrail indicating changes to IAM permissions.	Replace broad managed policies with custom least-privilege policies, review IAM permissions regularly, and use IAM Access Analyzer to identify excessive access.	AWS IAM, IAM Access Analyzer, AWS CloudTrail
Potential Privilege Escalation Through IAM Role Trust Policy	AssumeRole events recorded in CloudTrail from unexpected principals or services attempting to use intern_role.	Restrict trust relationships to only approved principals, enable MFA where applicable, and monitor role assumption activity using CloudTrail and CloudWatch.	AWS IAM, AWS CloudTrail, Amazon CloudWatch, IAM Access Analyzer
Insufficient Monitoring of IAM Activity	Frequent IAM policy changes, failed authentication attempts, or unusual API activity detected in CloudTrail logs.	Enable continuous logging with CloudTrail, configure CloudWatch alarms for IAM changes, and review logs regularly for suspicious activity.	AWS CloudTrail, Amazon CloudWatch, AWS Security Hub

5.2 Risk Exposure Over Time

Risk 1 — Broad S3 Read Permissions

If broad S3 read permissions remain in place, a compromised IAM account could access data beyond the resources required for normal operations. Over time, this increases the likelihood of unauthorized data exposure or data exfiltration from multiple S3 buckets rather than only the intended my-homelab-trail bucket. Implementing a bucket-specific least-privilege policy significantly reduces this risk by limiting access to only the required resources.

Risk 2 — Excessive IAM Permissions Through Managed Policies

Using AWS managed policies that grant broader permissions than necessary increases the attack surface of the AWS environment. If an attacker compromises an IAM user or group with excessive permissions, they may be able to enumerate resources, modify permissions, or access services unrelated to their intended role. Regular IAM permission reviews and replacing broad managed policies with custom least-privilege policies help reduce the long-term risk of privilege misuse.

Risk 3 — Potential Privilege Escalation Through IAM Role Trust Policies

Although the `intern_role` trust relationship was appropriately configured for this lab, overly permissive trust policies in a production environment could allow unauthorized principals to assume privileged IAM roles. If left unaddressed, attackers could obtain elevated permissions, perform unauthorized actions, and maintain persistence within the AWS environment. Restricting trusted principals, enabling MFA where applicable, and monitoring AssumeRole activity with AWS CloudTrail reduce the likelihood of privilege escalation and improve overall account security.

6.0 Recommendations

6.1 Technical Remediation

#	Finding	Specific Remediation Action (with Policy / CLI where applicable)	Priority	Standard / Reference
1	Broad S3 Read Permissions	Replace the <code>AmazonS3ReadOnlyAccess</code> managed policy with a custom least-privilege policy that limits <code>s3:ListBucket</code> and <code>s3:GetObject</code> to the my-homelab-trail bucket. Validate the policy using the IAM Policy Simulator or: <code>bash\naws iam simulate-principal-policy --policy-source-arn arn:aws:iam::*****:user/intern_user --action-names s3:GetObject --resource-arns arn:aws:s3:::my-homelab-trail/test.txt\n</code>	Immediate	CIS AWS Foundations Benchmark v1.5 – IAM Least Privilege NIST SP 800-53 AC-6
2	Excessive IAM Permissions Through Managed Policy	Replace AWS managed policies with customer-managed policies that grant only the permissions required for the user's responsibilities. Review IAM permissions regularly using IAM Access Analyzer and remove unnecessary permissions.	Short-term	CIS AWS Foundations Benchmark – IAM Controls NIST SP 800-53 AC-2
3	Potential Privilege Escalation Through IAM Role Trust Policy	Review and restrict the trust policy of <code>intern_role</code> so that only approved AWS services or principals can assume the role. Monitor AssumeRole events using AWS CloudTrail and configure CloudWatch alarms for unexpected role assumption activity.	Short-term	NIST SP 800-53 AC-3, AC-6 MITRE ATT&CK T1078
4	Limited Monitoring of IAM Activity	Enable AWS CloudTrail for all regions, integrate with Amazon CloudWatch for alerting, and periodically review IAM activity logs to detect unauthorized policy changes, failed logins, or unusual API calls.	Long-term	CIS AWS Foundations Benchmark – Logging & Monitoring NIST SP 800-53 AU-2, AU-6

6.2 Strategic & Operational Improvements

- **Implement a least-privilege IAM governance process.**
Establish a periodic IAM access review process to ensure that users, groups, and roles receive only the permissions required for their responsibilities. Replace broad AWS managed policies with customer-managed policies wherever practical to reduce the risk of excessive permissions.
- **Enable continuous IAM monitoring and auditing.**
Configure AWS CloudTrail to log all IAM and S3 API activity and integrate it with Amazon CloudWatch to generate alerts for high-risk events such as AttachUserPolicy, PutRolePolicy, AssumeRole, and DeletePolicy. This improves visibility into unauthorized permission changes and potential privilege escalation attempts.
- **Adopt IAM Access Analyzer as a standard security control.**
Regularly use AWS IAM Access Analyzer to identify overly permissive IAM policies, unintended external access, and trust relationship issues. Incorporating these reviews into routine security assessments helps detect access control weaknesses before they become security incidents.
- **Standardize secure IAM policy development.**
Develop and maintain reusable customer-managed IAM policy templates based on the principle of least privilege. Validate all new or modified policies using the AWS IAM Policy Simulator before deployment to reduce configuration errors and ensure permissions are limited to the required resources.
- **Strengthen account-level security controls.**
Enforce multi-factor authentication (MFA) for privileged IAM users, review IAM roles and trust policies regularly, and enable AWS Security Hub and AWS Config to continuously monitor security best practices and identify configuration drift across the AWS account.

7.0 Reflection

[Assessors look for evidence of genuine engagement — answers grounded in your specific lab experience, not generic textbook responses. Target 3–5 sentences per answer. Where a question asks you to communicate to a non-technical stakeholder, write your answer in plain language.]

Do not write 'N/A' for any reflection question. If you are unsure, describe what you would expect based on what you learned.

Q1 How would excessive use of wildcard permissions impact business risk in a multi-account enterprise environment?

During this lab, I observed that broad IAM permissions, such as AmazonS3ReadOnlyAccess, provided access beyond what was required for the task. In a multi-account enterprise environment, wildcard permissions (for example, s3:* or *) could allow a compromised account to access resources across multiple applications or business units. This increases the risk of unauthorized data access, privilege escalation, and regulatory non-compliance. Applying least-privilege policies that restrict access to specific resources, such as the my-homelab-trail bucket used in this lab, significantly reduces this risk.

Q2 What are the trade-offs between usability and security when designing IAM roles?

This lab demonstrated that broad permissions are easier to manage because users can perform many tasks without permission errors. However, this convenience comes at the cost of increased security risk because users may receive access that is not required for their responsibilities. Designing IAM roles with least-privilege permissions requires more planning and maintenance, but it reduces the attack surface and limits the impact if credentials are compromised. A balanced approach is to create roles based on specific job functions and review permissions regularly as responsibilities change.

Q3 How can automated tools help maintain compliance with least privilege over time?

Automated AWS services such as IAM Access Analyzer, AWS Config, CloudTrail, and Security Hub can continuously monitor IAM policies and identify permissions that are broader than necessary. During this lab, I used policy analysis and simulation to validate access before applying changes. In a production environment, these automated tools can detect policy changes, generate alerts, and identify overly permissive access without requiring constant manual reviews. This helps organizations maintain compliance with least-privilege principles as cloud environments evolve.

Q4 If you discovered an overly permissive cross-account trust relationship in production, what would be your immediate mitigation steps?

My first priority would be to reduce the risk by updating the IAM role trust policy so that only approved AWS accounts or services can assume the role. I would then review recent CloudTrail logs to determine whether the role had already been used unexpectedly and identify any suspicious activity. After containing the issue, I would validate the updated trust relationship using the IAM Policy Simulator or AWS CLI and notify the security team so the incident could be documented and monitored. Finally, I would recommend a broader review of other IAM roles to ensure similar trust relationship issues do not exist elsewhere in the environment.

8.0 Deliverables Submission Checklist

[Complete this checklist before submitting. Fill in the actual filename you produced for each phase. If a phase produced multiple files, list all of them separated by commas. If a deliverable does not apply to your specific task, write N/A in the Status column and briefly explain why in the Deliverable Description cell.]

✓	Phase	Deliverable Description	Your Filename	Status
☐	Phase A	Screenshot of Policy Simulator results showing denied/allowed actions.	phaseA_policy_simulator.png	Complete
☐	Phase B	Screenshots of console showing user/group/role creation; CLI output logs saved as `phaseB_output.txt`.	phaseB_user.png phaseB_group.png phaseB_role.png phaseB_inline_policy.png phaseB_user_group_membership.png phaseB_output.txt	Complete
☐	Phase C	Policy JSON files (`policy_analysis.json`), screenshot of AI feedback summary.	phaseC_policy_analysis.json phaseC_ai_feedback.png	Complete
☐	Phase D	Threat model diagram or table (`threat_model.pdf`), simulation output logs.	phaseD_simulation.txt phased_threat_model.pdf	Complete
☐	Phase E	Lab completion certificates or screenshots labeled `labE_results.png`.	PhaseE_CyberMind_Lab.png	Did for one lab
☐	Report	This report — exported as PDF using the naming convention below	CSE_CSE-AWS-L-005-04_S.K_20260805.pdf	Complete

Submission naming convention:

- Report PDF: CSE_[TaskID]_[YourInitials]_[YYYYMMDD].pdf
- Evidence folder: [TaskID]_Evidence_[YourInitials]/ — zip all phase files together

i Example: CSE-APPSEC-L-006-04_MAR_20251105.pdf and CSE-APPSEC-L-006-04_Evidence_MAR.zip

Declaration & Sign-Off

I confirm that:

- All work in this report is my own except where AI usage is explicitly declared in Section 2.3.
- All technical activities were performed exclusively within the authorised cloud environments listed in Section 1.3.
- No external AWS accounts, production environments, third-party cloud resources, or real customer data were accessed during this task.
- All AWS credentials, access keys, session tokens, and account identifiers used during this task have been redacted in evidence files before submission.
- I have reviewed this report for accuracy, completeness, and professional presentation before submission.

Intern Full Name	Signature	Date of Submission
Sukhmandeep Kaur	Sukhmandeep Kaur	05-August-2026

EncryptEdge Labs Limited — Junior Cloud Security Engineer Internship Programme

Company No. 15830711 | United Kingdom | encryptedgelabs.com

Copyright © 2026 EncryptEdge Labs. All rights reserved. | Report Template v3.0